

TUGAS 10

DESKRIPSI TUGAS

Bagian 1: Diagram Alur Otentikasi dan Otorisasi API

Tugas pertama adalah membuat diagram alur otentikasi dan otorisasi API yang menggambarkan penggunaan OAuth2/OIDC dan JWT. Diagram ini harus mencakup langkah-langkah yang diperlukan untuk proses login, pemberian izin oleh pengguna, pengeluaran token, dan penggunaan token untuk mengakses API.

Langkah-langkah yang harus digambarkan dalam diagram:

1. Login Pengguna: Pengguna diminta untuk login dengan kredensial mereka ke Authorization Server (misalnya, Google, Facebook, atau sistem internal).
2. Pemberian Izin oleh Pengguna: Setelah login, pengguna diberikan opsi untuk memberikan izin kepada aplikasi untuk mengakses data mereka (misalnya, profil atau data akun).
3. Pengeluaran Authorization Code: Jika pengguna memberikan izin, Authorization Server mengeluarkan authorization code kepada aplikasi.
4. Pengeluaran Access Token: Aplikasi menggunakan authorization code untuk mendapatkan access token dari Authorization Server.
5. Akses API dengan Token: Aplikasi menggunakan access token yang diterima untuk melakukan panggilan ke Resource Server dan mengakses data pengguna.
6. Pemeriksaan Scopes dan Roles: Resource Server memverifikasi access token dan memeriksa scopes dan roles yang ada dalam token untuk menentukan hak akses pengguna.

Petunjuk untuk Pembuatan Diagram:

- Gunakan alat pembuat diagram seperti Lucidchart, Draw.io, atau Microsoft Visio.
- Buat diagram alur yang menunjukkan aliran data antara Pengguna, Authorization Server, Aplikasi/Client, dan Resource Server.
- Diagram harus mencakup langkah-langkah yang jelas dan mudah dipahami, serta hubungan antar komponen yang terlibat dalam proses otentikasi dan otorisasi.

Bagian 2: Kontrol Keamanan API

Pada bagian kedua, Anda diminta untuk merancang kontrol keamanan API yang menggunakan OAuth2/OIDC dan JWT. Anda perlu menjelaskan bagaimana roles dan scopes digunakan untuk memastikan kontrol akses yang tepat.

Langkah-langkah yang harus dijelaskan:

1. Penerapan Scopes dan Roles:
 - Jelaskan bagaimana scopes dan roles digunakan untuk mengontrol akses ke data.
 - Scopes mendefinisikan jenis akses yang diminta oleh aplikasi (misalnya, read, write, admin).
 - Roles mendefinisikan tingkat akses yang diberikan kepada pengguna (misalnya, admin, user, guest).
2. Strategi Pengelolaan Token:
 - Rotasi Token: Jelaskan cara memperbarui token yang kedaluwarsa, menggunakan refresh token untuk memperpanjang masa berlaku access token.

- Pengaturan Masa Berlaku Token: Tentukan waktu kedaluwarsa untuk access token dan bagaimana aplikasi menangani token yang telah kedaluwarsa.
- Token Revocation: Jelaskan proses pencabutan token jika pengguna logout atau akses mereka dibatalkan.

3. Keamanan Token:

- Jelaskan bagaimana token harus disimpan dan dikirim dengan aman, menggunakan HTTPS untuk enkripsi transmisi.
- Jelaskan cara menghindari token hijacking dengan mengamankan token yang disimpan (misalnya, dengan Secure HTTPOnly Cookies).

4. Verifikasi Token di Resource Server:

- Resource Server harus memverifikasi JWT dan memeriksa signature, scopes, dan roles untuk memastikan pengguna memiliki akses yang sesuai.

Petunjuk untuk Rancangan Kontrol Keamanan:

- Tuliskan penjelasan yang rinci mengenai bagaimana kontrol akses (scopes dan roles) diterapkan untuk menjaga agar pengguna hanya dapat mengakses data yang sesuai dengan hak akses mereka.
- Jelaskan secara rinci bagaimana token management diterapkan untuk mengelola masa berlaku token, rotasi token, dan pencabutan token.
- Buatlah penjelasan yang jelas mengenai bagaimana keamanan transmisi token dan keamanan penyimpanan token dijaga untuk menghindari kebocoran data.